

API Contract — Backend xolvon.com

Daftar endpoint + kebutuhan auth. Dokumen ini bertambah setiap modul baru dan disempurnakan penuh di T16 (.omo/plans/xolvon-backend-build.md).

- **Status dokumen:** skeleton per T4. Kolom status menandai `aktif` (sudah ada di repo) atau `planned` (didefinisikan plan, belum diimplementasikan).
- **Global prefix:** semua route dilayani di bawah `/api/*` (`src/main.ts`).
- **Auth:** Authorization: Bearer `<accessToken>` (JWT) — Bearer-only, tidak ada cookie session (DL-016/DL-018). Role: `user` (default) dan `admin` (`RolesGuard`). Mutation browser request (`POST/PATCH/DELETE`) additionally lolos request-integrity guard `src/common/guards/request-integrity.guard.ts` (T3): `Origin/Referer` harus ada dalam set asal yang diizinkan, `Sec-Fetch-Site: cross-site` ditolak; request non-browser tanpa header asal lolos (tetap butuh Bearer valid).
- **Validasi:** global `ValidationPipe` (`whitelist`, `forbidNonWhitelisted`, `transform`) — field di luar DTO ditolak.
- **Error:** global `AllExceptionsFilter` — respons aman, tanpa stack trace/internal.
- **Pagination:** kontrak terkunci di decision log DL-011 — `?page=` 1-based, `?limit=` default 20 maks 100, respons `{items, page, limit, total}`.
- **Rate limit** (per IP, jendela 60 detik, via `@nestjs/throttler` named groups — DL-012 + implementasi T6 di `src/config/throttle.config.ts`): `/auth/login` + `/auth/register` **5/min**; katalog publik list (`GET /courses`, `/projects`, `/marketplace`, `/collective`, `/home`) **30/min** (group `catalog`); `GET /search` **30/min** (group `search`); signed-URL issuance (`GET /lessons/:id/video-url`, `POST /admin/media/upload-url`, `POST /admin/media/read-url`) **10/min** (group `signed`); `POST /orders` **10/min** (group `order`); rute tak berhias lain **100/min** (group `default`). Health `GET /api` dikecualikan dari SEMUA group (`@SkipThrottle` eksplisit per nama tracker).
- **Audit:** mutation sensitif (verify/activate/revoke/publish/cancel) menulis `admin_audit_logs` (plan T11/T15).

Endpoint aktif (sudah ada di repo)

Auth (src/auth/auth.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
POST	<code>/api/auth/register</code>	Public	-	aktif	Registrasi user baru; <code>role</code> tidak pernah diterima dari input (DL-005)	<code>RegisterDto</code>	<code>SafeUserDto</code> (201)
POST	<code>/api/auth/login</code>	Public	-	aktif	Login; mencatat IP + user agent ke sesi; rate limit menyusul (DL-012)	<code>LoginDto</code>	<code>AuthResponseDto</code> { <code>accessToken</code> , <code>refreshToken</code> , <code>user</code> : <code>SafeUserDto</code> } (200)
POST	<code>/api/auth/refresh</code>	Public	-	aktif	Terbit access token baru via refresh token	<code>RefreshTokenDto</code>	{ <code>accessToken</code> } (200)
POST	<code>/api/auth/logout</code>	Public	-	aktif	Revoke sesi refresh token	<code>LogoutDto</code>	{ <code>message</code> } (200)
GET	<code>/api/auth/me</code>	Bearer JWT	user	aktif	Profil user dari payload JWT sesi	-	<code>JwtPayload</code> (200)
GET	<code>/api/auth/admin</code>	Bearer JWT	admin	aktif	Cek akses admin	-	{ <code>message</code> , <code>user</code> } (200)

Orders (src/orders/orders.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
POST	<code>/api/orders</code>	Bearer JWT	user	aktif	Checkout; total dihitung server-side; status awal <code>pending</code> (DL-002)	<code>CreateOrderDto</code>	<code>OrderResponseDto</code> (201)
POST	<code>/api/orders/:id/payment-proof</code>	Bearer JWT	owner order	aktif	Submit object key bukti bayar; cek kepemilikan anti-IDOR	<code>SubmitPaymentProofDto</code>	{ <code>message</code> , <code>proofId</code> } (201)
PATCH	<code>/api/orders/:id/verify</code>	Bearer JWT	admin	aktif	Verifikasi pembayaran → <code>paid</code> ; setelah rekonsiliasi T3 hanya dari <code>pending</code> (DL-002) + audit	-	<code>OrderResponseDto</code> (200)
POST	<code>/api/orders/:id/activate</code>	Bearer JWT	admin	aktif	Aktivasi enrollment dari order <code>paid</code> ; idempoten via upsert	-	<code>OrderActivationResponseDto</code> (200)

Enrollments (src/enrollments/enrollments.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api/enrollments/me</code>	Bearer JWT	user	aktif	Daftar enrollment milik sesi (anti-IDOR, dari <code>user.sub</code>)	-	<code>EnrollmentResponseDto[]</code> (200)
PATCH	<code>/api/enrollments/:id/revoke</code>	Bearer JWT	admin	aktif	Revoke enrollment → <code>revoked</code> + audit (plan T15)	-	<code>EnrollmentResponseDto</code> (200)

App (src/app.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api</code>	Public	-	aktif	Health check / hello	-	<code>string</code> (200)

Search (src/search/search.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api/search</code>	Public	-	aktif	Pencarian lintas course, project, dan marketplace; hanya <code>published</code> ; FTS5; <code>?q=</code> opsional, <code>?type=course</code>	<code>project</code> <code>marketplace</code> opsional, pagination DL-011	<code>SearchQueryDto</code> { <code>items</code> : <code>SearchResultDto[]</code> , <code>query</code> , <code>page</code> , <code>limit</code> , <code>total</code> } (200)

`SearchResultDto` hanya memuat {`type`, `id`, `title`, `slug`, `description`, `status`}. Search tidak pernah mengembalikan draft, private, admin-only, unpublished, atau revoked content; seluruh search term dan pagination memakai DTO validation serta bind parameters.

Home (src/home/home.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	<code>/api/home</code>	Public	-	aktif	Agregasi homepage published-only (featured courses, projects, marketplace, collective) tanpa N+1; throttled group <code>catalog</code>	-	<code>HomeResponseDT0</code> { <code>courses[]</code> , <code>projects[]</code> , <code>marketplace[]</code> , <code>collective[]</code> } (200)

Courses (src/courses/courses.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response	
GET	/api/courses	Public	-	aktif	Katalog published-only. ?q= contains pada title (LIKE, wildcard di-escape), ?sort=latest	oldest' (default latest), pagination DL-011	-	{items: CourseCardDto[], page, limit, total, query} (200)
GET	/api/courses/:slug	Public	-	aktif	Detail published-only (draft → 404) + lessons terurut order_index ASC → ringkasan aman tanpa content / video_object_key / signed URL (SCHEMA.md §17)	-	CourseDetailDto (200) / 404	
POST	/api/courses	Bearer JWT	admin	aktif	Buat course (status awal draft, UUID server-generated) + audit create; slug unik	CreateCourseDto	CourseCardDto (201)	
PATCH	/api/courses/:id	Bearer JWT	admin	aktif	Update parsial + audit update; slug baru dicek unik	UpdateCourseDto	CourseCardDto (200)	
POST	/api/courses/:id/publish	Bearer JWT	admin	aktif	Transisi ketat draft → published, gate field wajib (description, price) + audit publish	-	CourseCardDto (200)	
POST	/api/courses/:id/unpublish	Bearer JWT	admin	aktif	Transisi ketat published → draft + audit unpublish	-	CourseCardDto (200)	
GET	/api/courses/:slug/lessons	Public	-	aktif	Daftar lesson published milik course published (src/lessons/course-lessons.controller.ts), urut order_index ASC: ringkasan aman tanpa content / video_object_key	-	LessonSummaryDto[] (200)	

CourseCardDto (SCHEMA.md §16): {id, title, slug, description, price,

thumbnailUrl, status}. CourseDetailDto menambahkan lessons:

LessonSummaryDto[] dengan LessonSummaryDto = {id, title, orderIndex, status}.

Collective (src/collective/collective.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	/api/collective	Public	-	aktif	Member published-only. ?q= (LIKE name/role/skills), pagination DL-011, urut display_order ASC lalu created_at DESC	-	PaginatedCollectiveResponseDto {items, page, limit, total} (200)
GET	/api/collective/:slug	Public	-	aktif	Detail member + relatedProjects via project_members (published); TIDAK pernah memuat email/telepon (SCHEMA.md §57)	-	CollectiveMemberDetailDto (200) / 404
POST	/api/collective	Bearer JWT	admin	aktif	Buat member (status awal draft) + audit create	CreateCollectiveMemberDto	CollectiveMemberResponseDto (201)
PATCH	/api/collective/:id	Bearer JWT	admin	aktif	Ubah member + audit update	UpdateCollectiveMemberDto	CollectiveMemberResponseDto (200)
POST	/api/collective/:id/publish	Bearer JWT	admin	aktif	Set status published + audit publish	-	CollectiveMemberResponseDto (200)
POST	/api/collective/:id/unpublish	Bearer JWT	admin	aktif	Set status draft + audit unpublish	-	CollectiveMemberResponseDto (200)

Projects (src/projects/projects.controller.ts, src/project-media/, src/project-members/)

Method	Path	Auth	Role	Status	Deskripsi	Request	Response	
GET	/api/projects	Public	-	aktif	Portfolio published-only. ?q= contains pada title/summary, ?sort=latest	oldest' (default latest), pagination DL-011	-	{items: ProjectCardDto[], page, limit, total} (200)
GET	/api/projects/:slug	Public	-	aktif	Detail published-only (draft → 404, sama seperti slug tak dikenal); urutan cerita Problem→Solution→Tech Stack→Result→Media (sort_order ASC, video dan object key dieksklusi) → members[].role dari JOIN collective_members (SCHEMA.md §47-48)	-	ProjectDetailDto (200) / 404	
POST	/api/projects	Bearer JWT	admin	aktif	Buat project (status awal draft) + audit create; slug unik; type string terkontrol (bukan enum final)	CreateProjectDto	ProjectResponseDto (201)	
PATCH	/api/projects/:id	Bearer JWT	admin	aktif	Update parsial + audit update; slug baru dicek unik	UpdateProjectDto	ProjectResponseDto (200)	
POST	/api/projects/:id/publish	Bearer JWT	admin	aktif	Transisi ketat draft → published, gate field wajib (title, slug, type, summary, problem, solution) + audit publish	-	ProjectResponseDto (200)	
POST	/api/projects/:id/unpublish	Bearer JWT	admin	aktif	Transisi ketat published → draft + audit unpublish	-	ProjectResponseDto (200)	
POST	/api/projects/:id/media	Bearer JWT	admin	aktif	Attach media (objectKey, mediaType string terkontrol → enum final open decision DL-014, sortOrder) + audit create	AttachProjectMediaDto	ProjectMediaResponseDto (201)	
DELETE	/api/projects/:id/media/:mediaId	Bearer JWT	admin	aktif	Detach media ter-scope ke project (lintas project → 404) + audit delete	-	{message} (200)	
POST	/api/projects/:id/members	Bearer JWT	admin	aktif	Assign collective member dengan role eksplisit (upsert ON CONFLICT(project_id, member_id); role string terkontrol (bukan enum final) + audit create	AssignProjectMemberDto	{projectId, memberId, role} (201)	
DELETE	/api/projects/:id/members/:memberId	Bearer JWT	admin	aktif	Remove assignment member ter-scope ke project + audit delete	-	{message} (200)	

ProjectCardDto (SCHEMA.md §46): {id, title, slug, type, summary, status}.

ProjectDetailDto (§47, urutan cerita §48): {id, title, slug, type, summary,

problem, solution, techStack: string[], result, media: {id, mediaType,

sortOrder}[], members: {memberId, name, role}[], status}' — media publik

tanpa objectKey, video dieksklusi (butuh signed private access, T13/T14).

Admin (src/admin/admin.controller.ts)

Method	Path	Auth	Role	Status	Deskripsi
GET	/api/admin/users	Bearer JWT	admin	aktif	Paginated user list.
GET	/api/admin/users/:id	Bearer JWT	admin	aktif	User detail.
GET	/api/admin/orders	Bearer JWT	admin	aktif	Paginated order list.
GET	/api/admin/overview	Bearer JWT	admin	aktif	User/order/enrollment summary.

Learning, media, and order operations

All routes in this table require Bearer JWT. Admin routes additionally require the `admin` role; user routes derive ownership from the JWT subject.

Method	Path	Role	Status	Deskripsi
POST	/api/courses/:courseId/lessons	admin	aktif	Create lesson.
PATCH	/api/lessons/:id	admin	aktif	Update lesson.
DELETE	/api/lessons/:id	admin	aktif	Delete lesson.
PATCH	/api/lessons/:id/reorder	admin	aktif	Reorder lesson.
POST	/api/lessons/:id/publish	admin	aktif	Publish lesson.
POST	/api/lessons/:id/unpublish	admin	aktif	Unpublish lesson.
POST	/api/lessons/:lessonId/resources	admin	aktif	Create resource.
DELETE	/api/resources/:id	admin	aktif	Delete resource.
GET	/api/lessons/:id/video-url	user	aktif	Signed lesson video URL for active enrollment.
POST	/api/progress	user	aktif	Write owned progress.
GET	/api/progress	user	aktif	Read owned progress.
PATCH	/api/enrollments/:id/revoke	admin	aktif	Revoke enrollment and audit.
POST	/api/orders/:id/cancel	admin	aktif	Cancel pending order and audit.
POST	/api/admin/media/upload-url	admin	aktif	Create validated media upload URL.
POST	/api/admin/media/confirm	admin	aktif	Confirm media upload.
POST	/api/admin/media/read-url	admin	aktif	Create private media read URL.

Historical implementation notes

The endpoint tables above are the active contract. The notes below preserve module-specific response and validation details from the implementation plan.

Courses — aktif (T5)

Endpoint sudah pindah ke tabel aktif di atas. `status` tidak pernah diterima dari input (DTO tidak memilikinya; global `ValidationPipe` `forbidNonWhitelisted` menolak field di luar DTO) — transisi status hanya via endpoint `publish/unpublish`.

Lessons & Course Resources — aktif (T6)

CRUD admin untuk lesson (`order_index`, draft/published) dan resource

pdf	resource	assignment; summary publik tanpa field privat.
-----	----------	--

Projects / Project Media / Project Members — aktif (T7)

Endpoint sudah pindah ke tabel aktif di atas. `type` (project), `mediaType` (media), dan `role` (member) divalidasi sebagai string terkontrol dengan batas panjang — BUKAN enum final (SCHEMA.md §45/§50/§52; open decision DL-014). Object key media privat tidak pernah muncul di respons publik.

Collective — aktif (T8)

Endpoint sudah pindah ke tabel aktif di atas. `skills` disimpan comma-separated TEXT dan `social_links` sebagai JSON array TEXT (SCHEMA.md §56); keduanya diparse di mapper menjadi `string[]` / `SocialLink[]` yang tidak pernah null.

Marketplace & Marketplace Media (T9, src/marketplace/)

Showcase murni — tidak ada logika transaksi/checkout (SCHEMA.md §60); satu-satunya permukaan komersial adalah `externalUrl` (validasi minimal https, DL-013; governance tetap OPEN — PRD §91.11).

Method	Path	Auth	Role	Status	Deskripsi	Request	Response
GET	/api/marketplace	Public	-	aktif	Listing published-only, ?q= (LIKE title/description, wildcard di-escape), "? sort=latest"	oldest' (default latest), pagination DL-011	- <pre>{items: MarketplaceItemDto[], page, limit, total} (200)</pre>

Method	Path	Auth	Role	Status	Deskripsi	Request	Response		
GET	/api/marketplace/:slug	Public	-	aktif	Detail published-only (draft → 404); media urut <code>sort_order</code> ASC; capabilities diparse dari comma-separated TEXT	-	MarketplaceItemDetailDto (200) / 404		
POST	/api/marketplace	Bearer JWT	admin	aktif	Buat listing (status awal <code>draft</code>) + audit <code>create</code> ; <code>externalUrl</code> wajib https valid	CreateMarketplaceItemDto	MarketplaceItemDto (201)		
PATCH	/api/marketplace/:id	Bearer JWT	admin	aktif	Update parsial + audit <code>update</code> ; slug baru dicek unik; <code>externalUrl</code> divalidasi ulang	UpdateMarketplaceItemDto	MarketplaceItemDto (200)		
POST	/api/marketplace/:id/publish	Bearer JWT	admin	aktif	Transisi ketat <code>draft</code> → <code>published</code> + audit <code>publish</code>	-	MarketplaceItemDto (200)		
POST	/api/marketplace/:id/unpublish	Bearer JWT	admin	aktif	Transisi ketat <code>published</code> → <code>draft</code> + audit <code>unpublish</code>	-	MarketplaceItemDto (200)		
POST	/api/marketplace/:id/media	Bearer JWT	admin	aktif	Attach media (objectKey R2, <code>mediaType</code> <code>image</code>)	video\	deck per SCHEMA.md §63 + audit <code>create</code>	AttachMarketplaceMediaDto	MarketplaceMediaDto (201)
DELETE	/api/marketplace/:id/media/:mediaId	Bearer JWT	admin	aktif	Detach media ter-scope ke item (lintas item → 404) + audit <code>delete</code>	-	{message} (200)		

MarketplaceItemDto (SCHEMA.md §59): `{id, title, slug, description, capabilities: string[], externalUrl, status}`.

Home — aktif (T10)

Agregasi published-only (featured courses, projects, marketplace, collective) tanpa N+1.

Audit — aktif internal (T11)

Belum ada endpoint — dan tidak akan punya endpoint publik. `record()` internal untuk modul lain; `metadata` tidak pernah keluar ke API publik/user.

Admin — aktif (T12)

Method	Path	Auth	Role	Deskripsi
GET	/api/admin/users	Bearer JWT	admin	Tabel users
GET	/api/admin/orders	Bearer JWT	admin	Tabel orders (kolom per PRD §45)
GET	/api/admin/overview	Bearer JWT	admin	userCount / pendingOrders / activeEnrollments

Media (R2) — aktif (T13)

Method	Path	Auth	Role	Deskripsi
POST	/api/admin/media/upload-url	Bearer JWT	admin	Presigned PUT 3600s; MIME/size/prefix divalidasi; key server-generated
POST	/api/admin/media/confirm	Bearer JWT	admin	Konfirmasi upload

Lessons video & Progress — aktif (T14)

Method	Path	Auth	Role	Deskripsi
GET	/api/lessons/:id/video-url	Bearer JWT	user aktif	Signed URL 300s; wajib enrollment aktif + lesson milik course (anti-IDOR)
POST	/api/progress	Bearer JWT	user aktif	Tulis progress; ownership dari sesi, bukan body

Orders (tambahan) — aktif (T15)

Endpoint sudah pindah ke tabel aktif di atas pada path kanonik `POST /api/orders/:id/cancel` (controller `src/orders/orders.controller.ts`, `@Controller('orders') + @Post('/:id/cancel')`). Catatan rekonsiliasi: dokumen awal pernah menuliskannya sebagai `POST /api/admin/orders/:id/cancel`; path tersebut TIDAK pernah ada di controller dan TIDAK ada di `docs/openapi.json` maupun Postman — kontrak kanonik adalah `POST /api/orders/:id/cancel`. Semantik tetap: hanya transisi `pending` → `cancelled` yang diizinkan, dan `cancel` menulis audit (plan T15).

Search — aktif (T16)

Endpoint lintas entitas sudah aktif pada tabel di atas. Search bersifat public, published-only, memakai FTS5, dan mengikuti kontrak pagination DL-011.

Catatan kontrak lintas-endpoint

- **Status order:** `pending` | `paid` | `cancelled` (DL-002); **status enrollment:** `active` | `revoked` (DL-004).
- **Tidak ada endpoint delete / role-change di V1** (DL-005, PRD §44 view-only).
- Tidak ada endpoint yang menerima `role` dari input user; tidak ada registrasi admin publik.
- Respons tidak pernah memuat `password_hash` , `refresh_token` , object key privat, kredensial R2, atau stack trace.
- Semua endpoint list (aktif maupun planned) mengikuti kontrak pagination DL-011.